TRIANGLE INFOSECON 2026 · LEADERSHIP TRACK

# When Everything Depends on Everything

What breaks when security fails in cascades, not silos.

Mike Faas · Fractional CTO/CISO

| IDENTITY | DEVICES | EMAIL | BACKUP |
|---|---|---|---|
| B | B | C | B |

| NETWORK | DATA PROTECTION | VENDOR RISK | INCIDENT READINESS |
|---|---|---|---|
| B | A | B | B |

# “Are we secure?”

| IDENTITY | DEVICES | EMAIL | BACKUP |
|---|---|---|---|
| B | B | C | B |

| NETWORK | DATA PROTECTION | VENDOR RISK | INCIDENT READINESS |
|---|---|---|---|
| B | A | B | B |

*“I can describe each square.*
*I can’t tell you what happens*
*when one of them fails.”*

# Eight grades.
# Zero lines between them.

# We score security like it's complicated.
# It isn't.

# Security doesn't fail in silos.
# It fails in cascades.

Three failures · the math · a graph · Monday

CIS · NIST · ISO · PCI · SOC 2

Decompose. Score each part.
**Add it up.**

# Eight domains. Eight dashboards. Eight budgets.
# Zero connections.

- Identity
- Devices
- Email
- Backup
- Network
- Data protection
- Vendor risk
- Incident readiness

# A cascade is a dependency.



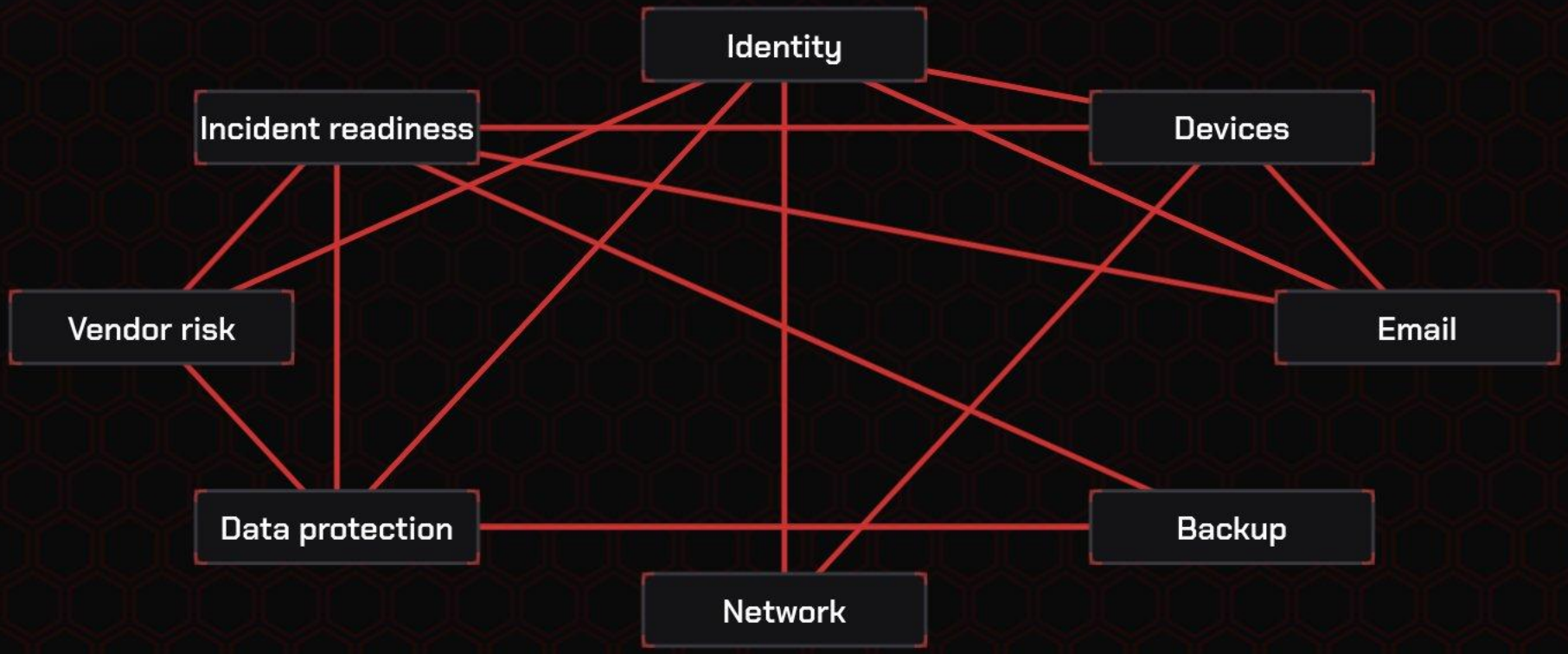

Square B needs square A to work.

# A cascade is a dependency.

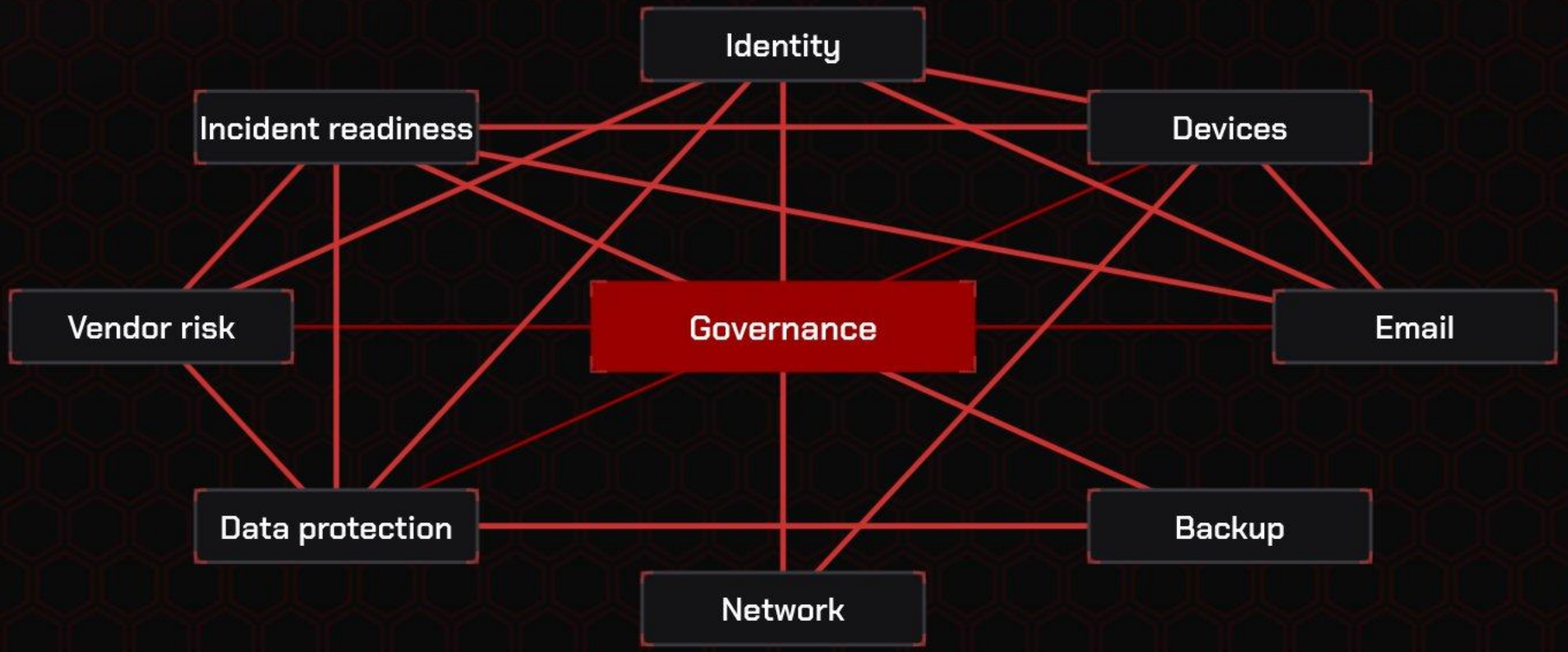



When A fails, B fails for A's reason.

# Pull one node. The web moves.



# Governance




It isn’t one of eight. It’s what the eight are standing on.

# Security doesn't fail in silos.
# It fails in cascades.

Take that sentence and go argue with it.

# You're not failing.
# The model you were handed is.

Anodot

Snowflake / BigQuery

Vimeo

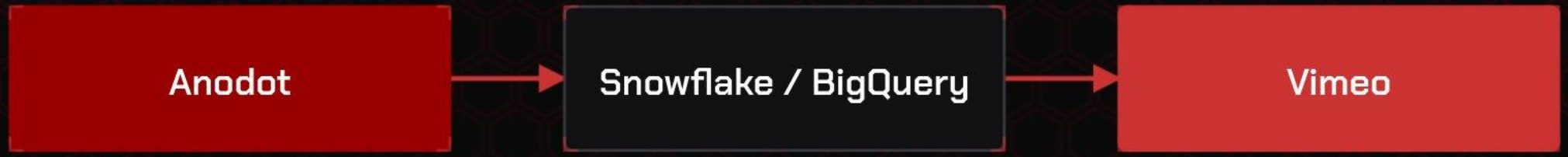
# April 28, 2026

Anodot

Snowflake / BigQuery

Vimeo

# Nobody broke into Vimeo.

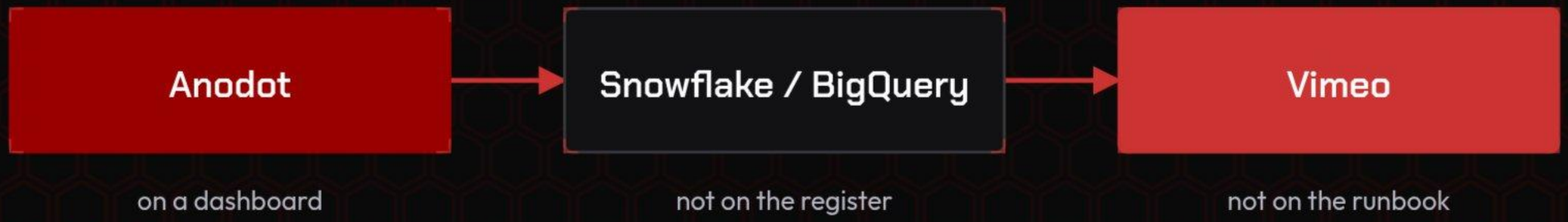


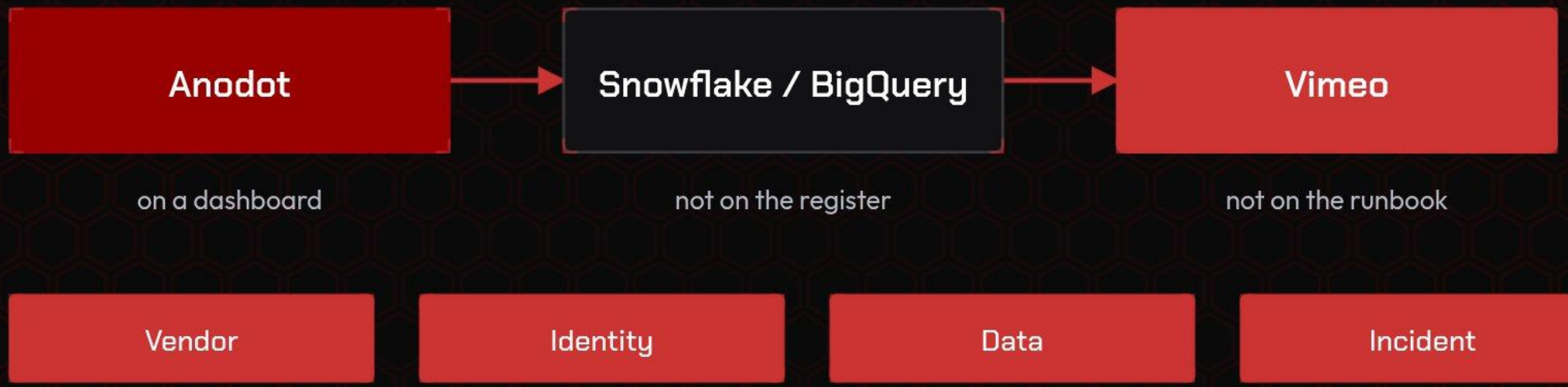

# They logged in. As Anodot.

**~119,000 people.**

Email addresses and metadata.

No passwords. No cards. No video.


Anodot
Snowflake / BigQuery
Vimeo
on a dashboard
not on the register
not on the runbook




# One integration. Four squares.

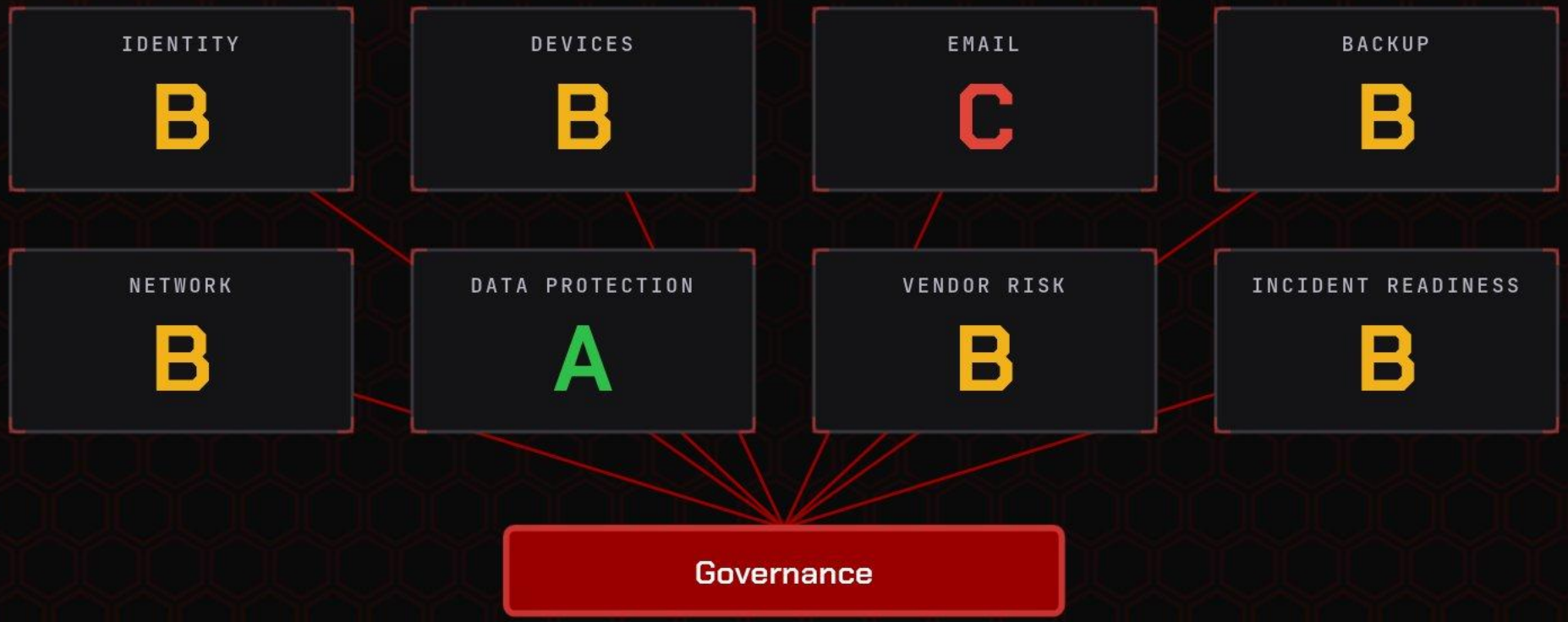
# MOVEit · Snowflake 2024 · Cleo

Different years. Different vendors. One shape.

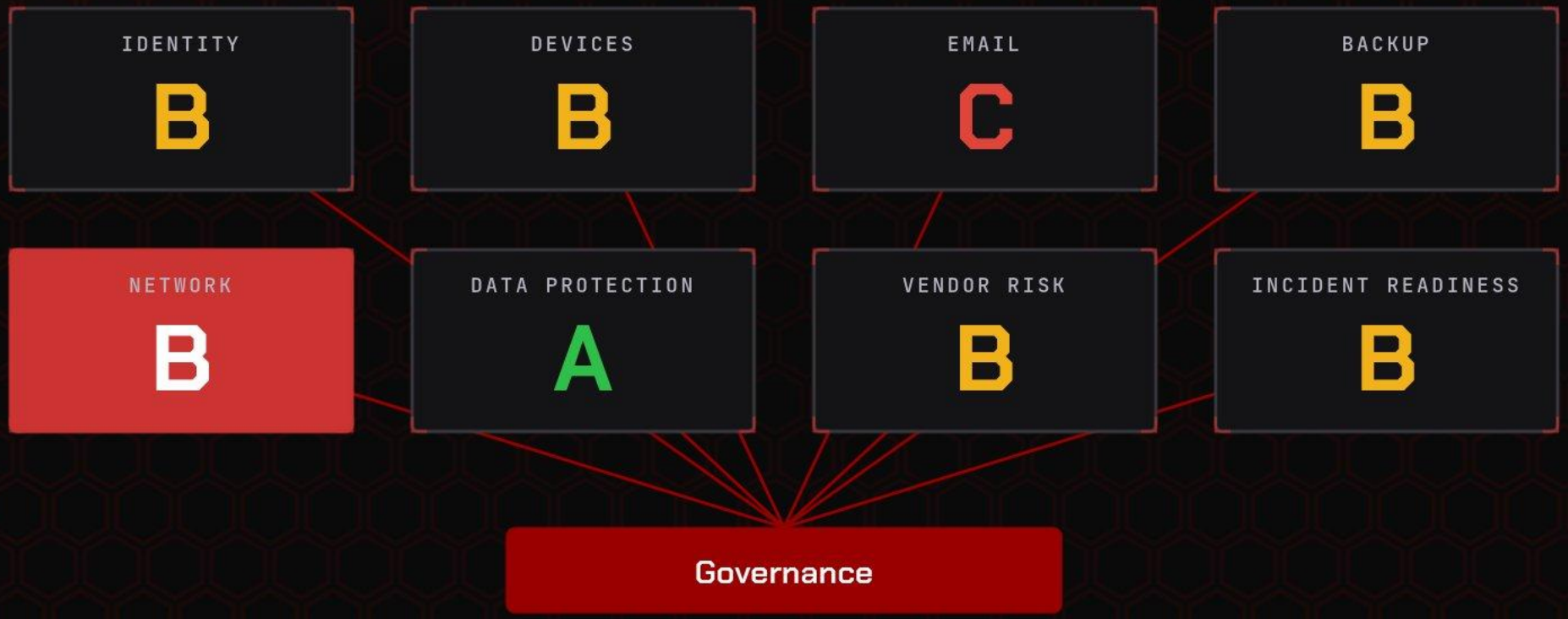
# Same shape.
# Different logos.

| IDENTITY | DEVICES | EMAIL | BACKUP |
|---|---|---|---|
| B | B | C | B |

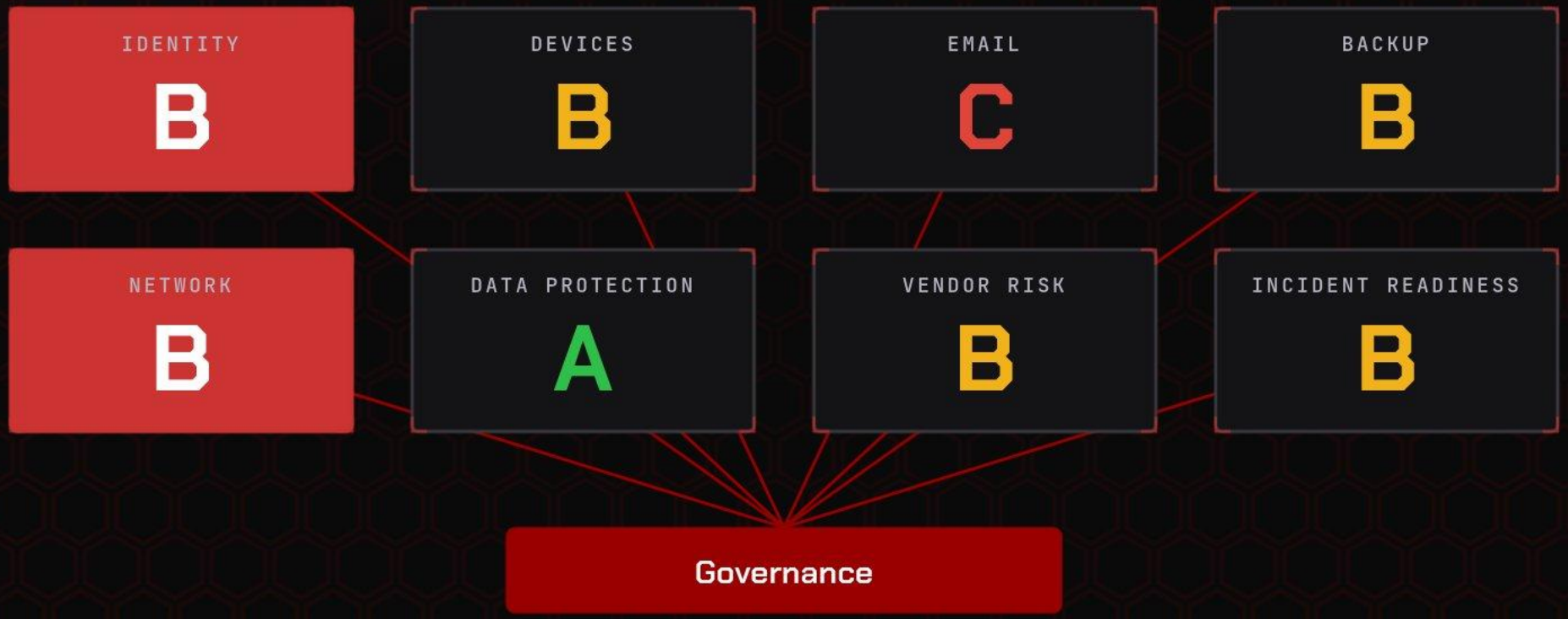
| NETWORK | DATA PROTECTION | VENDOR RISK | INCIDENT READINESS |
|---|---|---|---|
| B | A | B | B |



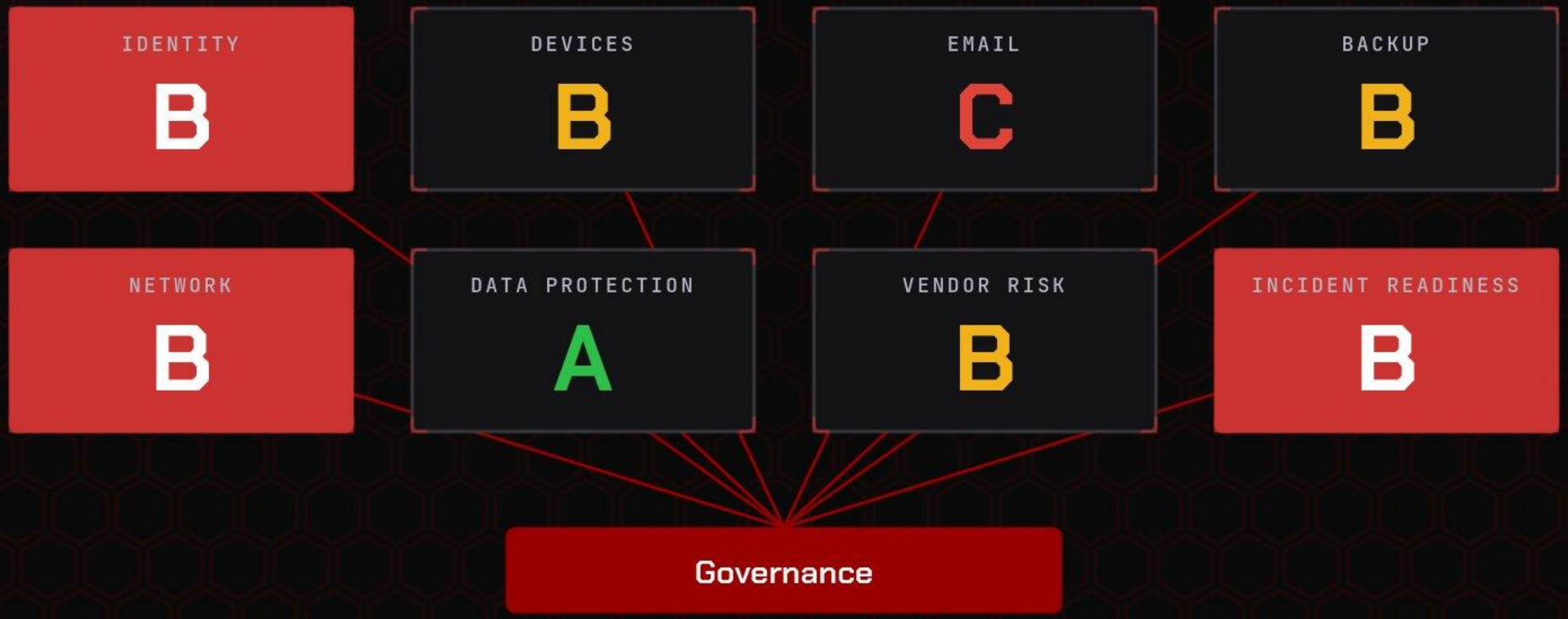

Not on the board. Not weak. Absent.



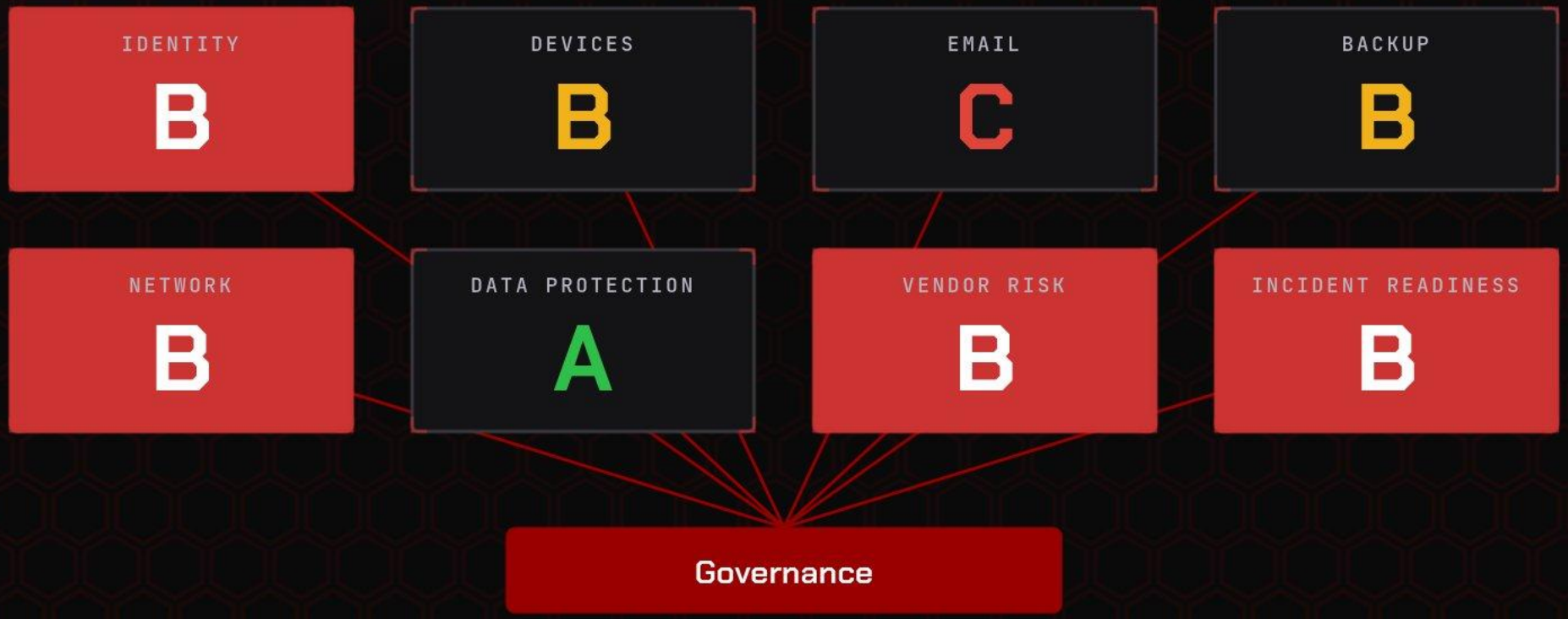

→ Audit finding



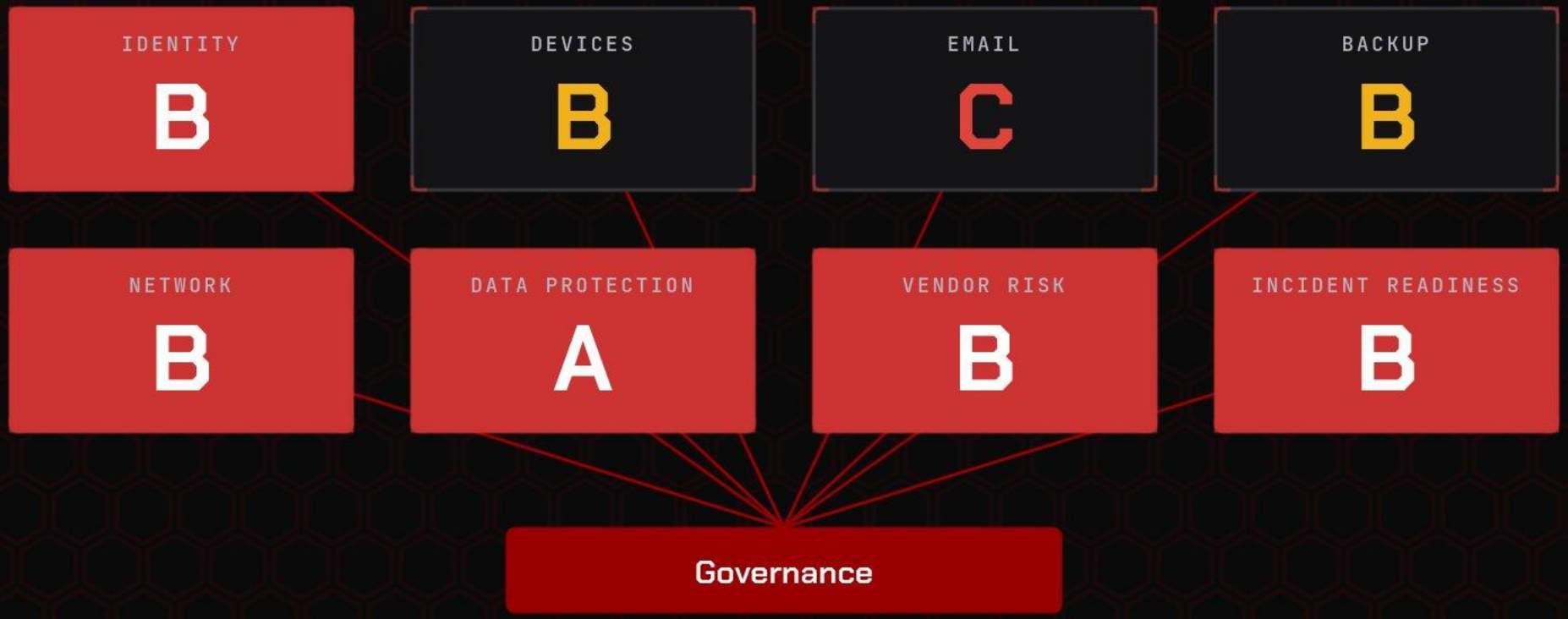

→ New engineer gets everything




→ No plan when someone clicks




→ “Describe your third-party risk program.”




→ Nobody classified anything

# Same gap.
# Different hats.

One gap. Five squares.
The grade said medium five times.

QUESTION 01

*How many SaaS integrations hold tokens to your data warehouse right now?*

QUESTION 01

*How many SaaS integrations hold tokens to your data warehouse right now?*

QUESTION 02

*How many of those does your security team know about?*

It's a cascade
you haven't drawn yet.

# Vendor & SaaS Risk

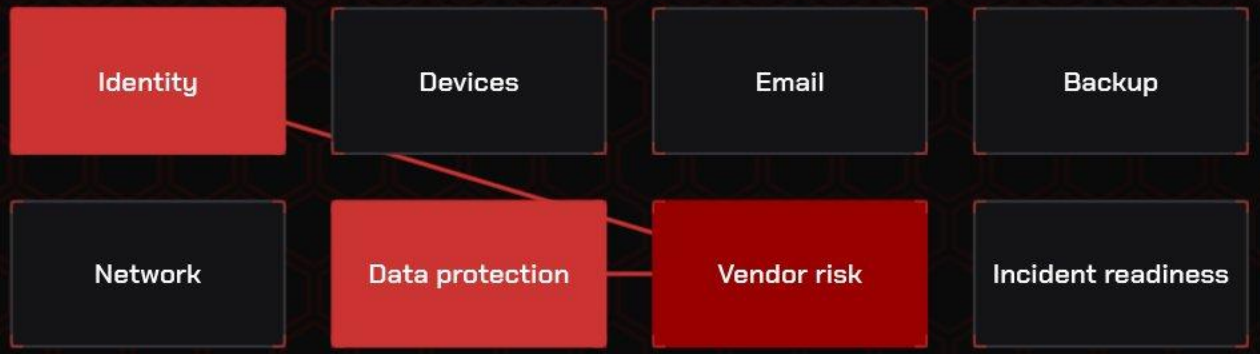



Register: “third-party risk, medium.”

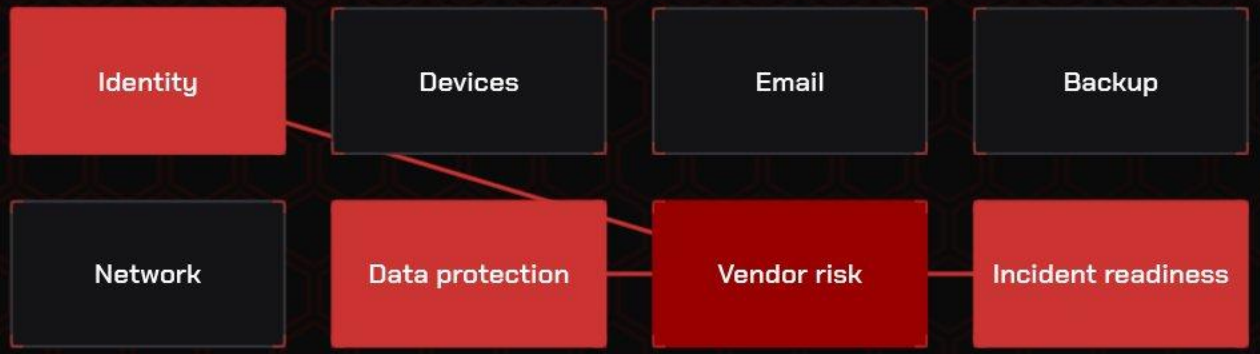
# → Identity & Access



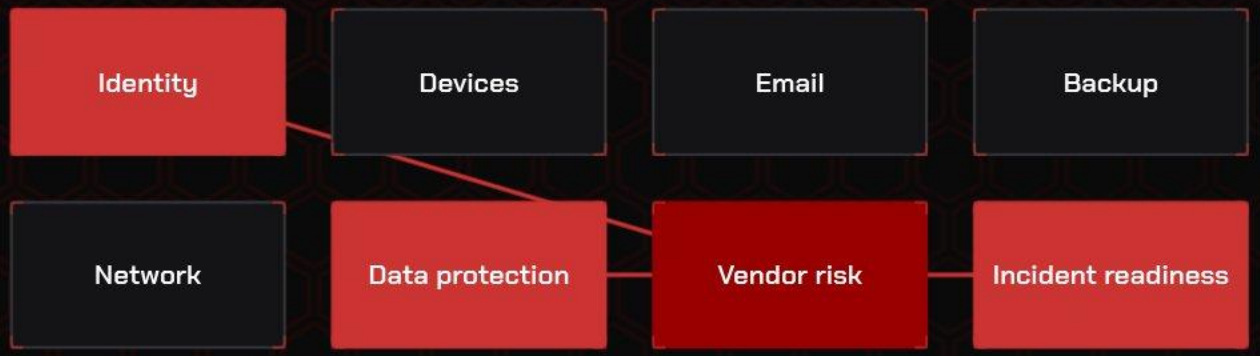
# → Data Protection



# → Incident Readiness

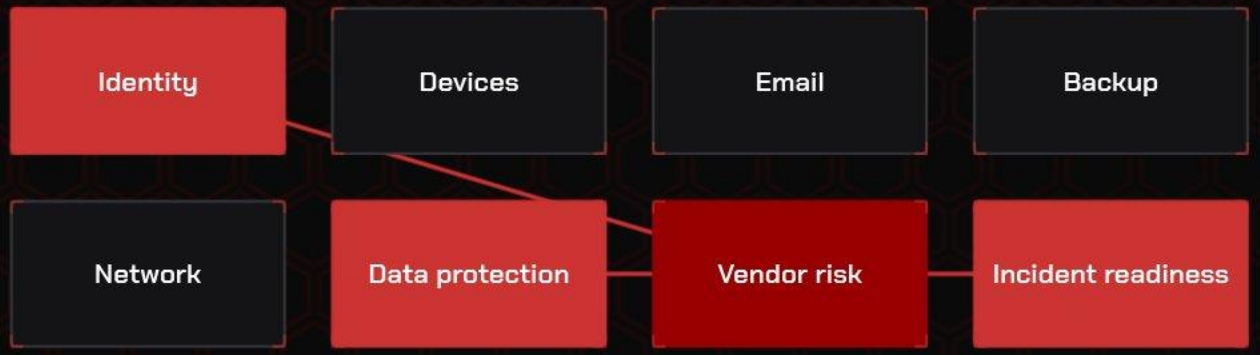


# The obligations




WHAT FIRES

# SOC 2

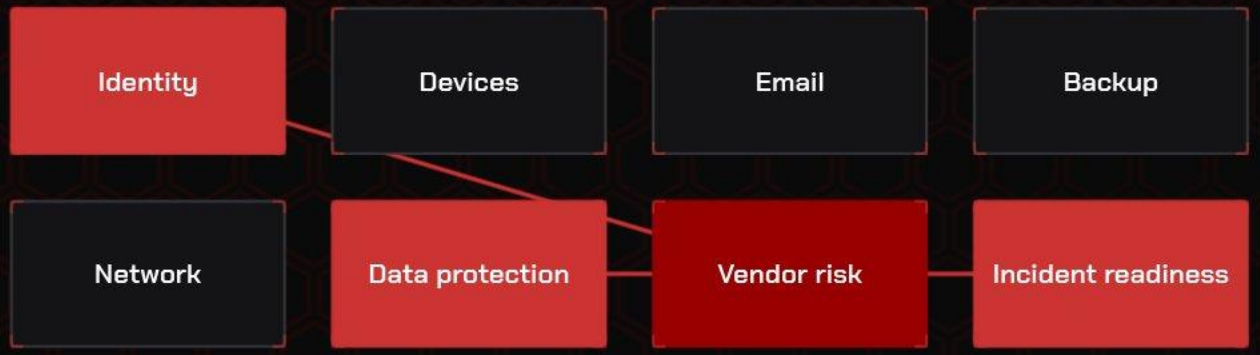



WHAT FIRES

**SOC 2**

CC9.2 · CC6 · CC7

# PCI DSS

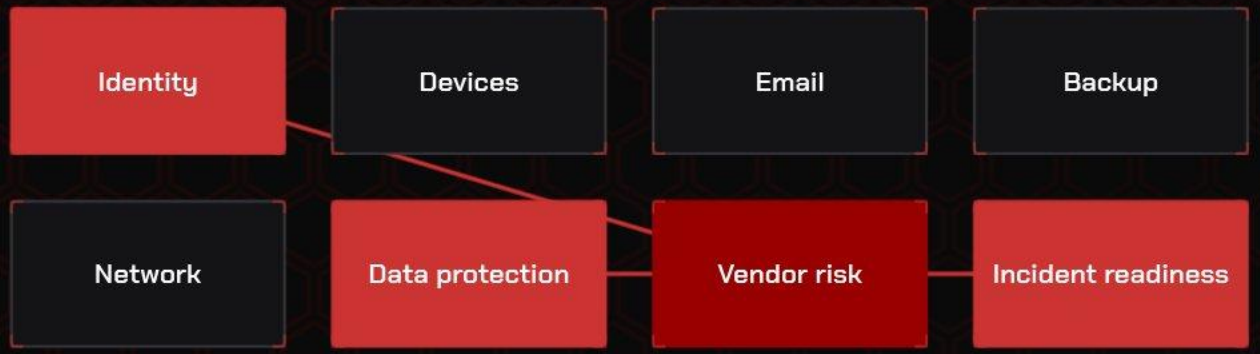



WHAT FIRES

**SOC 2**
CC9.2 · CC6 · CC7

**PCI DSS**
12.8 · 12.10

# HIPAA



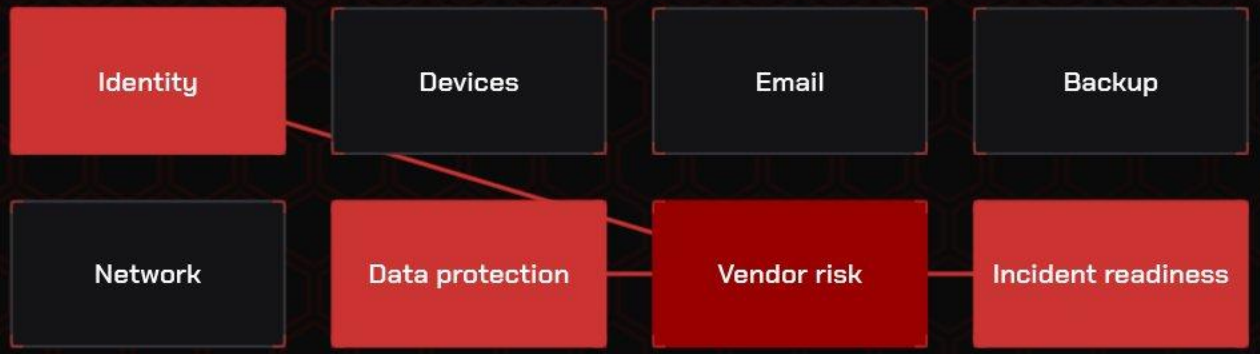

WHAT FIRES

**SOC 2**
CC9.2 · CC6 · CC7

**PCI DSS**
12.8 · 12.10

**HIPAA**
BAA · 164.404 · 60 days

# NC 75-65 · GDPR 33




WHAT FIRES

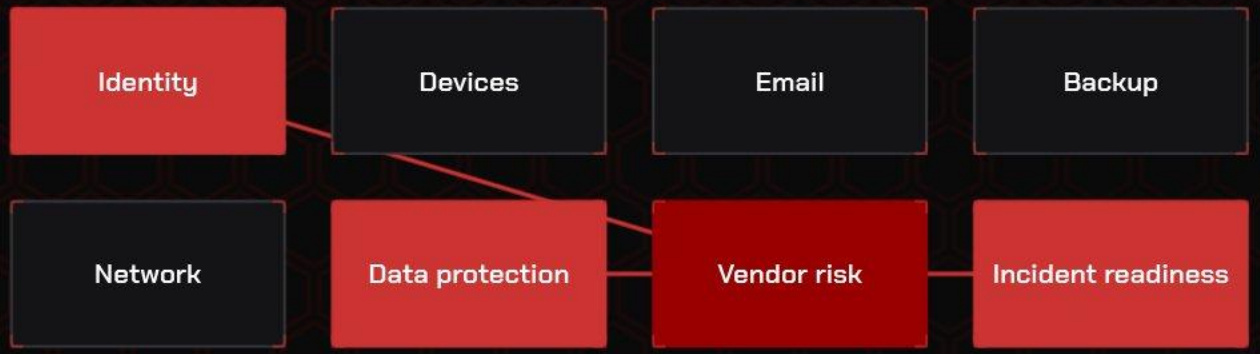
**SOC 2**
CC9.2 · CC6 · CC7

**PCI DSS**
12.8 · 12.10

**HIPAA**
BAA · 164.404 · 60 days

**NC 75-65 · GDPR 33**
without unreasonable delay · 72h

# Cyber insurance




WHAT FIRES

**SOC 2**
CC9.2 · CC6 · CC7

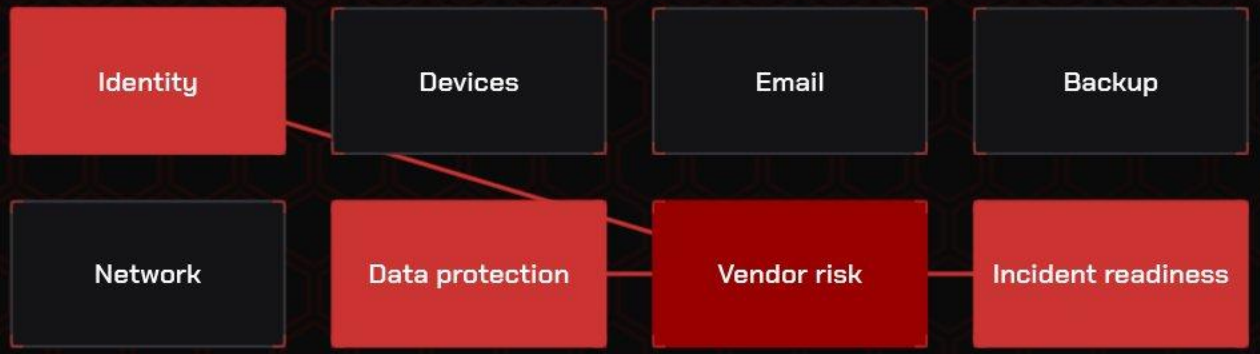
**PCI DSS**
12.8 · 12.10

**HIPAA**
BAA · 164.404 · 60 days

**NC 75-65 · GDPR 33**
without unreasonable delay · 72h

**Cyber insurance**
application warranties

# Customer MSAs




WHAT FIRES

**SOC 2**
CC9.2 · CC6 · CC7

**PCI DSS**
12.8 · 12.10

**HIPAA**
BAA · 164.404 · 60 days

**NC 75-65 · GDPR 33**
without unreasonable delay · 72h

**Cyber insurance**
application warranties

**Customer MSAs**
24h · 72h · promptly

# The math




1 gap · 4 domains · 7 obligation sets
7 clocks · 1 line on the register

WHAT FIRES

**SOC 2**
CC9.2 · CC6 · CC7

**PCI DSS**
12.8 · 12.10

**HIPAA**
BAA · 164.404 · 60 days

**NC 75-65 · GDPR 33**
without unreasonable delay · 72h

**Cyber insurance**
application warranties

**Customer MSAs**
24h · 72h · promptly

A graph.
Not a spreadsheet.
Not a maturity model.

# Sidekick Security · Trust Map

12 domains · 102 practices · 772 dependencies

# Same edges.
# Read backwards.

Dependency data: Sidekick Security Trust Map (public). Read backwards.

# One square on the board.



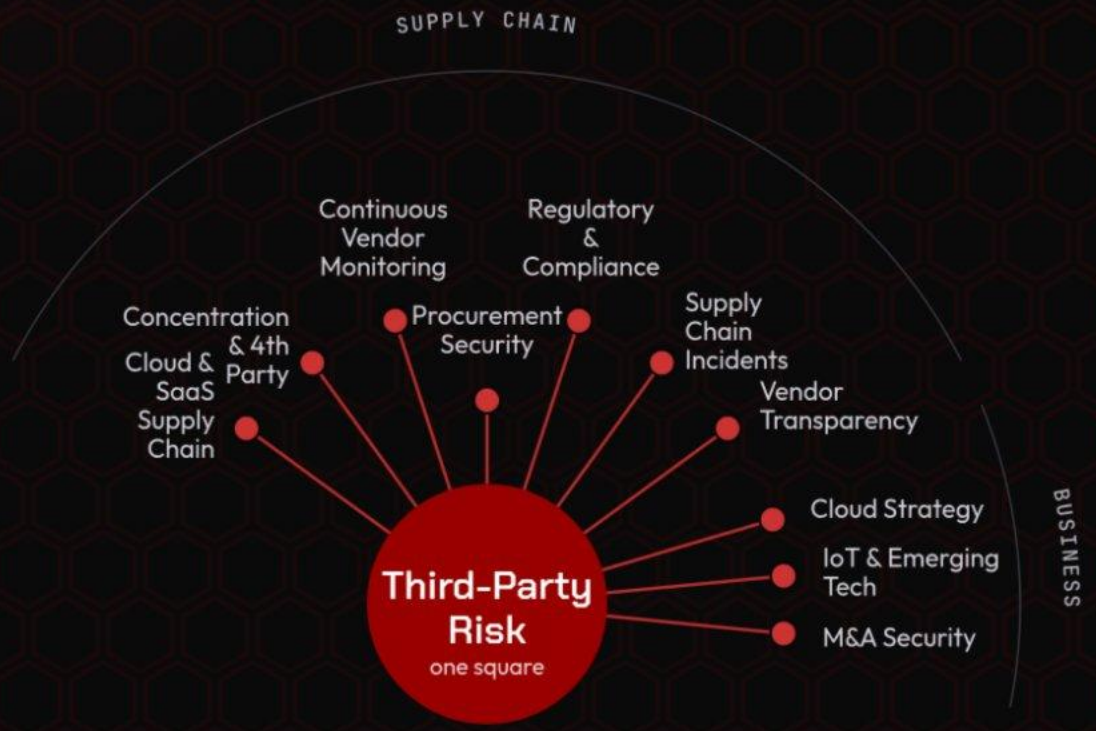
Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 7 so far · 1 domain



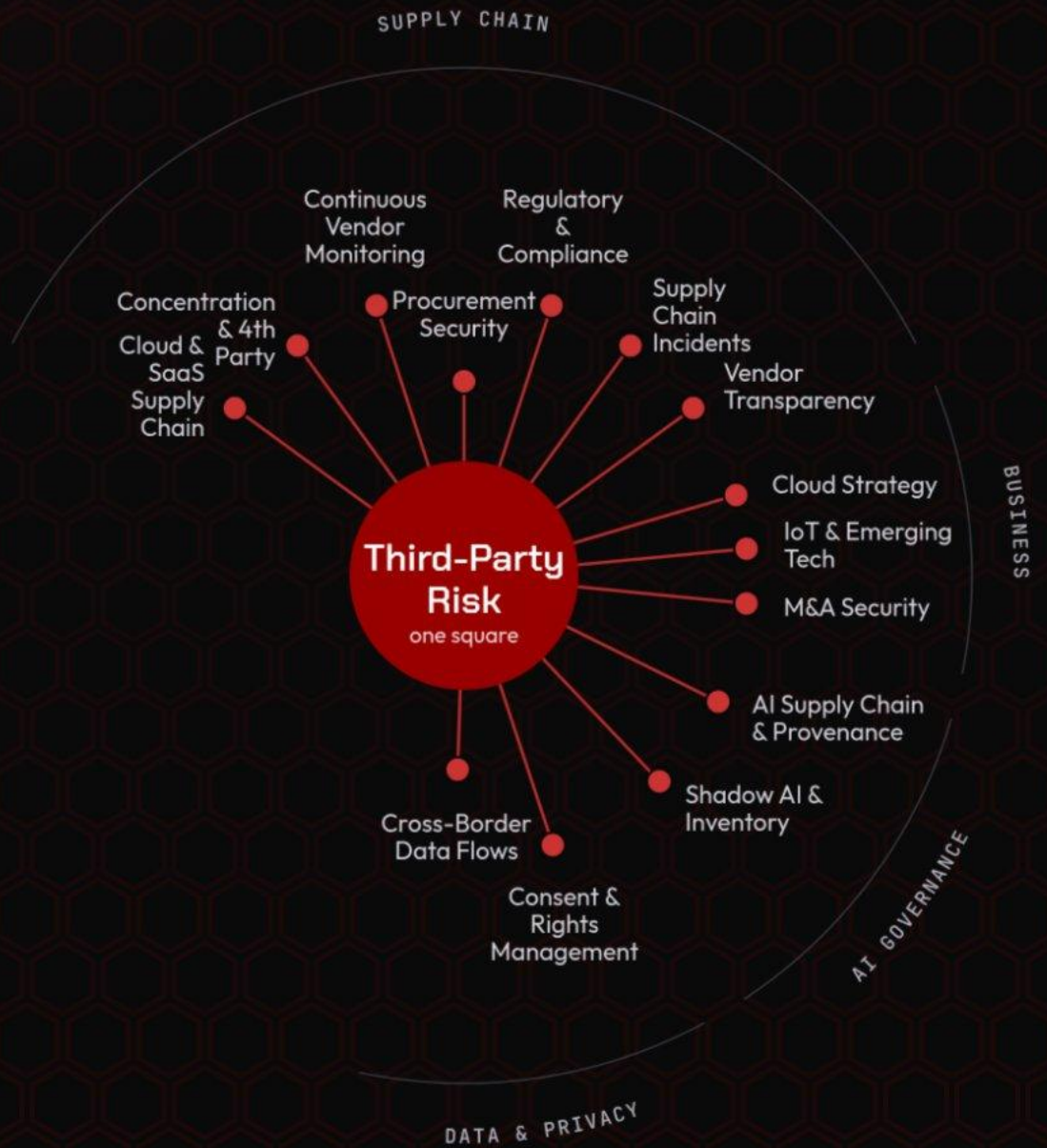
Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 10 so far · 2 domains



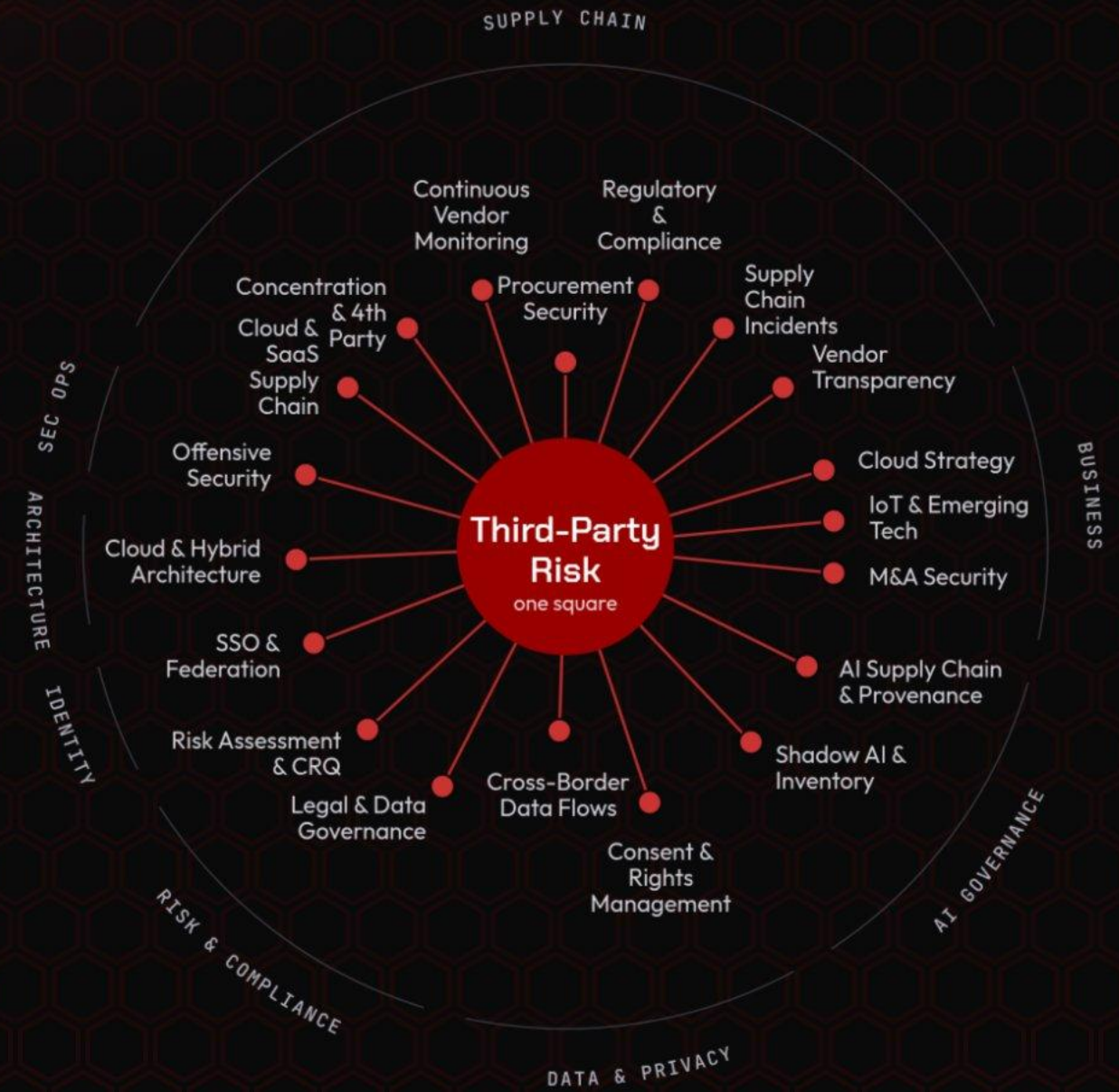
Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 14 so far · 4 domains



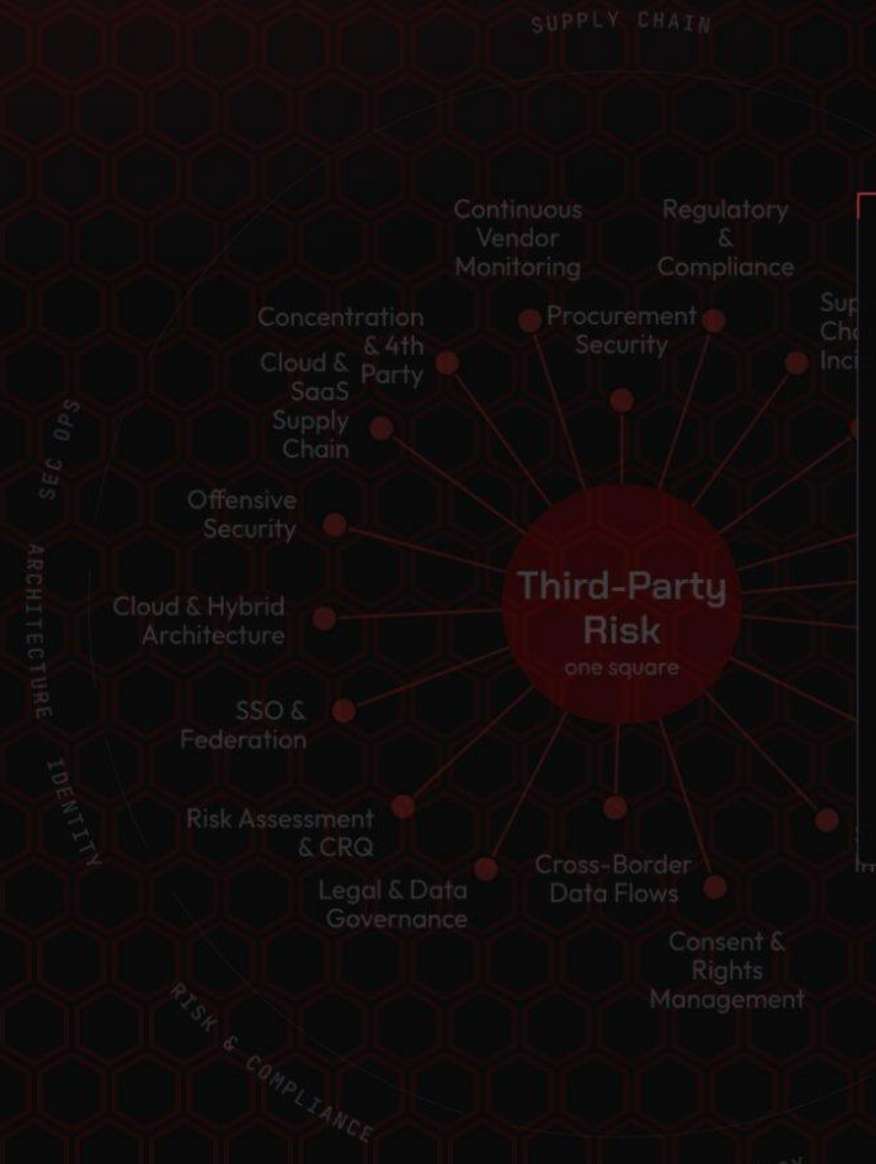
Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 19 practices fail for its reason · 8 domains



Dependency data: Sidekick Security Trust Map (public). Read backwards.

# Why, in their words




SSO & FEDERATION → DEPENDS ON THIRD-PARTY RISK

*"Third-party vendor access often requires federation: TPRM must evaluate vendor identity practices."*

LEGAL & DATA GOVERNANCE → DEPENDS ON THIRD-PARTY RISK

*"Vendor contracts and data processing agreements are negotiated through legal."*

CLOUD & HYBRID ARCHITECTURE → DEPENDS ON THIRD-PARTY RISK

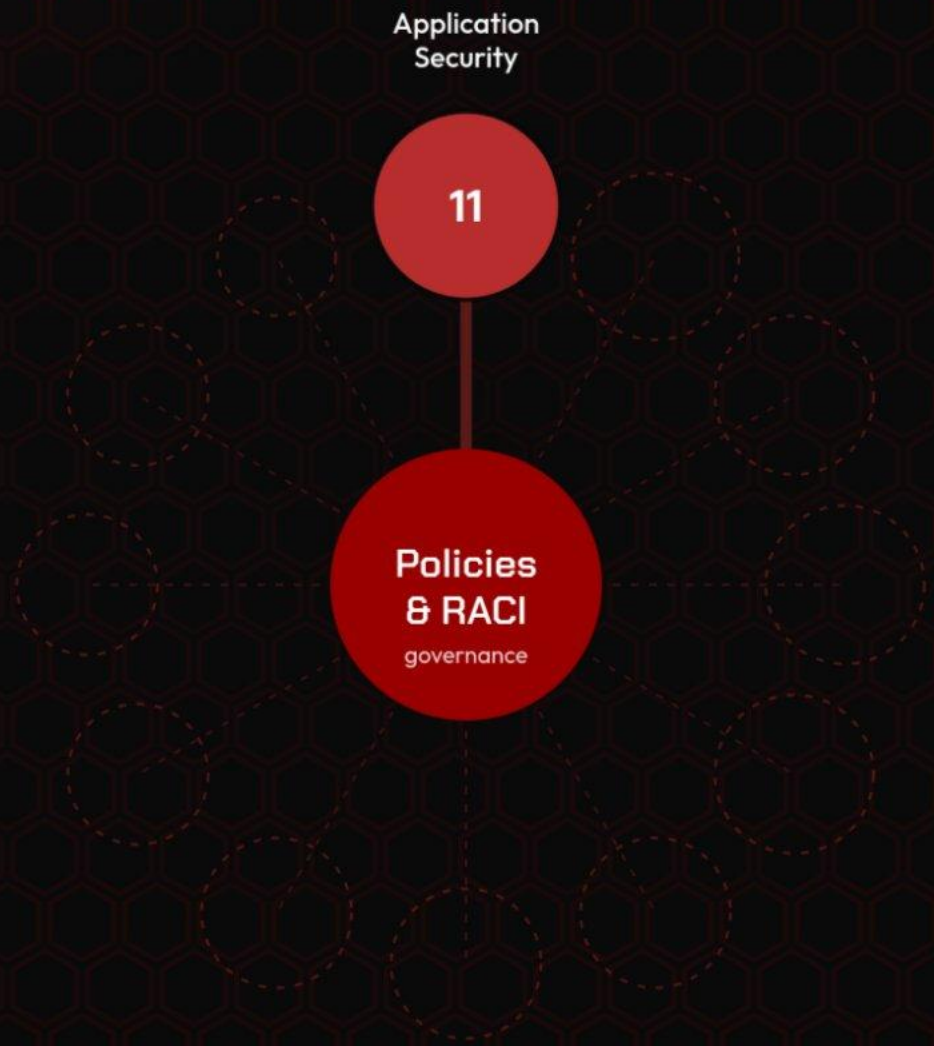
*"Cloud vendors are third parties: their security posture must be assessed through TPRM."*

M&A SECURITY → DEPENDS ON THIRD-PARTY RISK

*"Acquired company's vendor relationships become your third-party risk."*

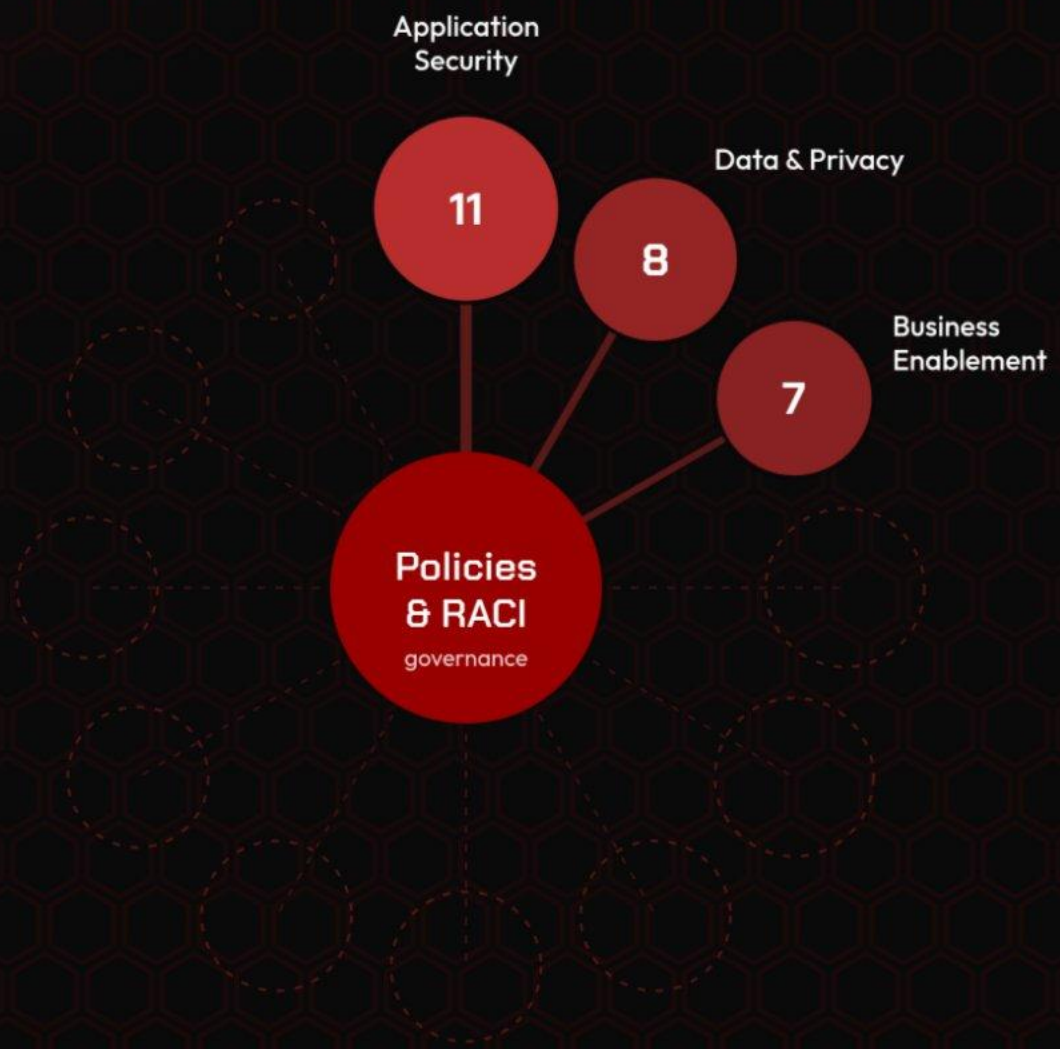
Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 11 in the first domain alone



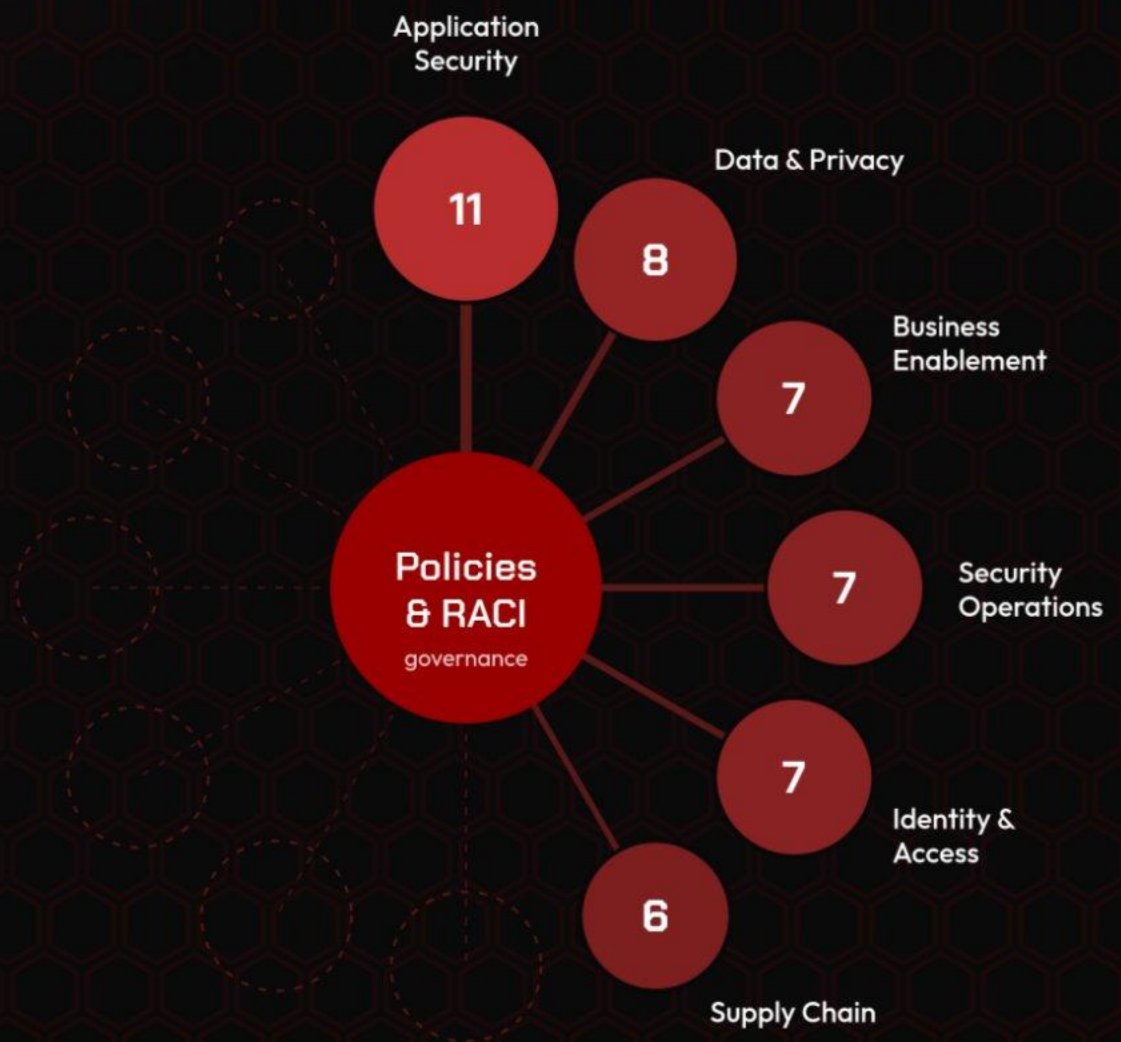
Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 26 so far · 3 domains



Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 46 so far · 6 domains



Dependency data: Sidekick Security Trust Map (public). Read backwards.

# 76 practices hang from it · all 12 domains

Next most-connected practice: 34



## THE EIGHT MOST-DEPENDED-ON PRACTICES

| | | |
|---|---|---|
| 1 | **Policies & RACI** | 76 |
| 2 | **Risk Assessment & CRQ** | 34 |
| 3 | **Compliance & Audits** | 27 |
| 4 | **Frameworks & Standards** | 25 |
| 5 | **Strategy & Alignment** | 24 |
| 6 | Data Governance & Classification | 22 |
| 7 | Threat Detection & SOC | 22 |
| 8 | Vulnerability Management | 21 |

Dependency data: Sidekick Security Trust Map (public). Read backwards.

*The domain I'd spent the least time on is the one **everything** hangs from.*

# Version one.
# Every edge counts the same.

It’s the structure, not your assessment.

# MONDAY MORNING

01

02

03

## MONDAY MORNING

01 Draw one edge.

02

03

# MONDAY MORNING

01 **Draw one edge.**

Hand it to the owner at the other end. Ask: did you know?

02

03

## MONDAY MORNING

01 **Draw one edge.**

Hand it to the owner at the other end. Ask: did you know?

02 **Find the tokens.**

03

## MONDAY MORNING

01 **Draw one edge.**

Hand it to the owner at the other end. Ask: did you know?

02 **Find the tokens.**

Two lists. The difference is your Anodot.

03

# MONDAY MORNING

## 01 Draw one edge.

Hand it to the owner at the other end. Ask: did you know?

## 02 Find the tokens.

Two lists. The difference is your Anodot.

## 03 Change the board slide.

# MONDAY MORNING

01 **Draw one edge.**

Hand it to the owner at the other end. Ask: did you know?

02 **Find the tokens.**

Two lists. The difference is your Anodot.

03 **Change the board slide.**

From “are we secure” to “what fails first.”

MONDAY MORNING

01 **Draw one edge.**

Hand it to the owner at the other end. Ask: did you know?

02 **Find the tokens.**

Two lists. The difference is your Anodot.

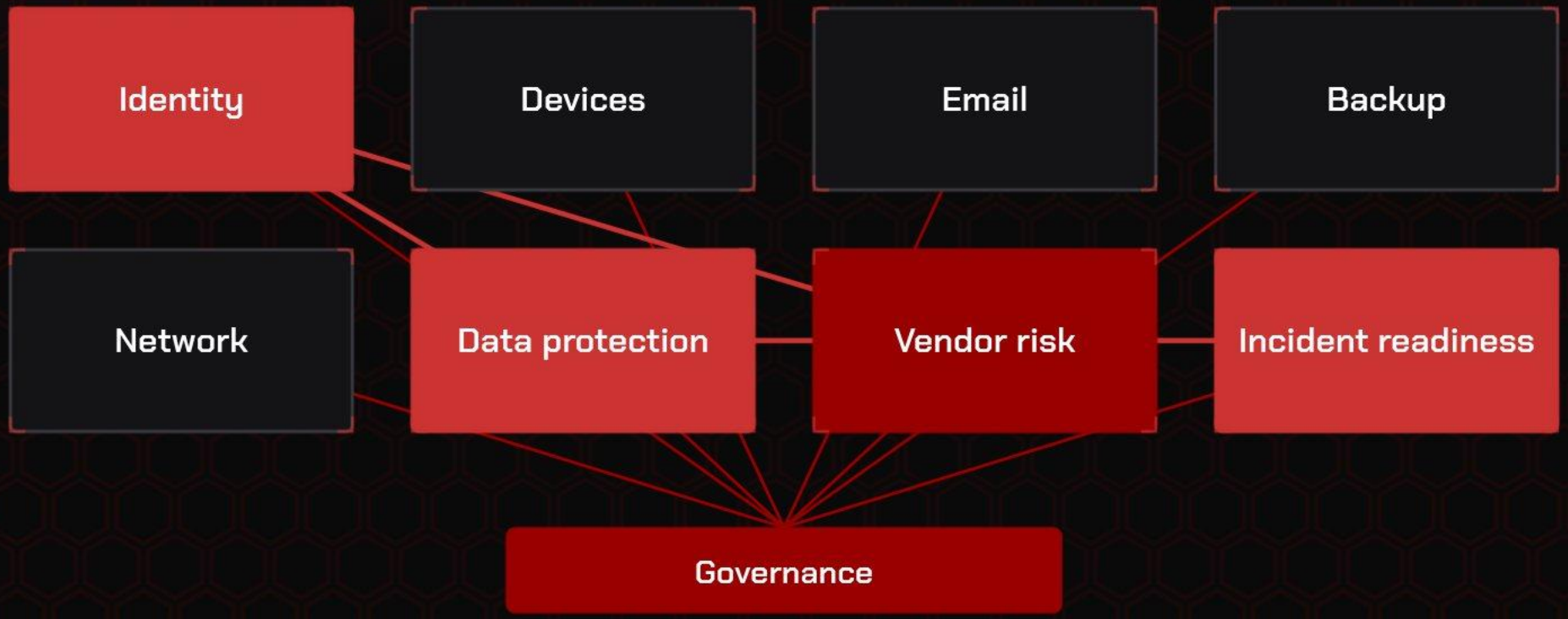
03 **Change the board slide.**

From “are we secure” to “what fails first.”

Complicated systems, you optimize.
Complex systems, you govern.




Same board. Same eight squares. Same B.




Same question. Different answer.

*“Here’s what fails first.*
*Here’s what it takes down with it.*
*And here’s whose name is on the line between.”*

# When everything depends on everything.

# Go draw the lines.

# Mike Faas

Fractional CTO/CISO

linkedin.com/in/mfaas

SLIDES

Sidekick Security, **The Trust Map** (2026) · Vimeo incident disclosure, Apr 2026 · MOVEit · Snowflake (2024) · Cleo · SOC 2 TSC · PCI DSS v4.0 · 45 CFR 164 · N.C.G.S. § 75-65 · GDPR Art. 33